

Security & Compliance

How hyper2kvm + hypersdk Protect Your Data During Migration

Zero telemetry. Zero cloud upload. Full air-gap support. HIPAA, SOC 2, GDPR, PCI DSS, FedRAMP, and STIG alignment. Open-source code auditable by your security team. Audit trail for every operation. Credential protection with vault integration. The most secure VM migration platform available.

Zero Telemetry | Air-Gap Ready | HIPAA/SOC2/GDPR/FedRAMP | Full Code Audit | Apache 2.0

Data Protection

Your VM data never leaves your control — not during migration, not ever.

0

Bytes sent to external
services — zero telemetry

0

Cloud dependencies
100% on-premises

0

Phone-home calls
no license server, no analytics

100%

Open source code
fully auditable on GitHub

No Cloud Upload

- hyper2kvm runs entirely on your infrastructure
- Disk images converted locally — never uploaded
- No external API calls during conversion
- No analytics, metrics, or usage tracking
- No third-party SaaS dependencies
- **Your data stays in your data center**

Encryption

- **At rest:** Output QCOW2 supports LUKS encryption
- **In transit:** vSphere exports via TLS 1.2+
- **SSH exports:** ed25519/RSA key authentication
- **KubeVirt uploads:** HTTPS with cert verification
- **FIPS mode:** Honors system OpenSSL FIPS config
- Encrypted vSAN/VMFS sources handled natively

Secure Cleanup

- Temporary files in /tmp auto-deleted after conversion
- Working directories cleaned on completion
- No residual disk data left on conversion host
- Intermediate formats (raw) removed after QCOW2 creation
- YAML configs can be purged after migration
- Configurable retention policy for audit logs

Air-Gapped Migration — Zero Internet Required

For classified, SCIF, TEMPEST, or fully disconnected environments:

- **Install:** Copy RPM/DEB/Python wheel + Go binary via USB or approved media

- **Export:** Transfer VMDKs/VHDs via encrypted external drive (FIPS-approved if required)
- **Convert:** Run hyper2kvm on isolated network — no internet, no DNS, no NTP dependency
- **Deploy:** virsh define locally or kubectrl apply on air-gapped K8s cluster
- **No phone-home:** hyper2kvm has zero network calls — no license check, no update check, no telemetry
- **Verified:** Checksums (SHA256) for all binaries — verify integrity before deployment

Regulatory Compliance

How hyper2kvm aligns with every major compliance framework.

Framework	Requirement	hyper2kvm Compliance	Evidence / Control
HIPAA	PHI must stay in controlled environment	All processing local, no cloud upload	Network audit: zero outbound connections during migration
HIPAA	Audit trail for PHI access	Structured JSON logging with trace IDs	hypersdk audit log: user, action, timestamp, IP, result
HIPAA	Encryption of PHI at rest	LUKS-encrypted QCOW2 output	qemu-img create with -o encrypt.format=luks
HIPAA	Access controls (minimum necessary)	sudo-only execution, RBAC in hypersdk	3 roles: admin, operator, viewer with resource-level permissions
SOC 2	Change management	YAML configs are version-controlled	Git history: exact config used for every migration, reproducible
SOC 2	Monitoring and alerting	Prometheus metrics + webhook alerts	/metrics endpoint, Slack/Teams/PagerDuty webhook on failure
SOC 2	Vendor risk management	Open source — no vendor dependency	Apache 2.0: no rug-pull, no license revocation, fork freedom
GDPR	Data residency (EU data stays in EU)	On-prem processing, no cross-border transfer	Migration runs on your servers, in your jurisdiction
GDPR	Right to erasure	Delete source + converted images completely	No copies retained by tool — you control all data lifecycle
GDPR	Data processing records	Audit log captures every operation	JSON log with timestamp, data processed, operator identity
FedRAMP	FIPS 140-2 cryptography	Uses system OpenSSL, FIPS mode honored	RHEL FIPS mode: all crypto operations through FIPS-validated modules
FedRAMP	Continuous monitoring	Prometheus metrics + structured logging	Dashboard integration with existing FedRAMP monitoring stack
PCI DSS	Network segmentation	Works on isolated networks, no external calls	Can run in PCI cardholder data environment with no internet

PCI DSS	Strong access control	RBAC + audit trail + JWT authentication	Per-user access control with full audit history
STIG	Hardened system configurations	Works on STIG-hardened RHEL/Ubuntu	No conflicts with STIG controls — tested on hardened images
ISO 27001	Information security management	Full audit, access control, encryption, monitoring	Supports all Annex A controls relevant to data migration

hypersdk Security Architecture

Enterprise-grade security built into every layer of the daemon.

Authentication

- **JWT tokens:** Short-lived, signed, with expiry
- **API keys:** For service-to-service auth
- **Session management:** Token rotation, forced logout
- **Password hashing:** bcrypt with configurable cost
- **Multi-factor:** Extensible auth port interface
- No default passwords — explicit setup required

RBAC Authorization

- **3 roles:** admin, operator, viewer
- **6 actions:** create, read, update, delete, export, cancel
- **Resource-level:** jobs, schedules, providers, config, users
- Permission matrix enforced at API middleware layer
- Denied access logged to audit trail
- Configurable per-endpoint authorization

Secret Management

- **SecretManager port:** Pluggable backends
- **Vault integration:** HashiCorp Vault support
- **File backend:** Encrypted local secret store
- **Env vars:** GOVC_PASSWORD, cloud API keys
- **Rotation:** Automatic secret rotation support
- Credentials never stored in YAML configs

Audit Logging

- **Every action logged:** login, export, create/cancel/delete job
- **Fields:** user, IP address, timestamp, action, resource, result
- **AuditLogger port:** File-based (default), extensible to SIEM
- **Tamper detection:** Append-only log with checksums
- Queryable history for compliance reviews
- 16+ audit event types covering full lifecycle

Network Security

- **TLS everywhere:** API server, provider connections
- **Certificate rotation:** Configurable TLS cert renewal
- **Rate limiting:** Per-user and global request limits
- **No inbound ports required:** Daemon initiates all connections
- Works behind firewalls and NAT
- Air-gap: zero network requirements

Credential Protection

- **vCenter passwords:** `vc_password_env` reads from env var
- **Cloud API keys:** Stored in SecretManager, not config files
- **Redaction:** `VCenterConfig.Redacted()` masks passwords in logs
- **No plaintext:** Credentials never appear in YAML, logs, or metrics
- SSH key-based auth (no password storage)
- Kubernetes secrets integration for K8s deployments

Audit Event Types

```
// All 16+ audit events tracked by hypersdk:  
AuditEventLogin      // User authentication
```

```
AuditEventLogout      // Session termination
AuditEventExportVM     // VM disk export operation
AuditEventCreateJob    // Migration job created
AuditEventCancelJob    // Migration job cancelled
AuditEventDeleteJob    // Migration job deleted
AuditEventCreateSchedule // Scheduled job created
AuditEventUpdateSchedule // Scheduled job modified
AuditEventDeleteSchedule // Scheduled job removed
AuditEventCreateWebhook // Webhook endpoint registered
AuditEventDeleteWebhook // Webhook endpoint removed
AuditEventCreateUser   // User account created
AuditEventUpdateUser   // User account modified (role change)
AuditEventDeleteUser   // User account removed
AuditEventConfigChange // System configuration changed
```

Guest VM Security Hardening

hyper2kvm doesn't just migrate VMs — it hardens them during the process.

Hardening Action	What hyper2kvm Does	Security Benefit	Compliance Alignment
SELinux relabel	Creates /.autorelabel for full restorecon on first boot	All file contexts correct for KVM — no permissive mode needed	STIG, HIPAA, FedRAMP
VMware Tools removal	Removes open-vm-tools packages, services, and agents	Eliminates unnecessary attack surface from source hypervisor	CIS Benchmarks, SOC 2
Hyper-V IC removal	Disables hv_kvp, hv_vss, hv_fcopy daemons	Removes services that could leak info or accept commands	CIS Benchmarks, SOC 2
Cloud agent removal	Disables AWS SSM, Azure waagent, GCP guest-agent	Prevents agents from phoning home to cloud metadata services	GDPR, data sovereignty
Minimal VirtIO drivers	Injects only required drivers (blk, net, scsi)	No unnecessary kernel modules — minimal attack surface	STIG, CIS Benchmarks
fstab UUID stabilization	Converts device paths to UUID-based mounts	Prevents mount confusion attacks from device reordering	System integrity
Network cleanup	Removes old NIC configs with hardcoded MACs	Clean network state — no stale firewall rules or routing	PCI DSS segmentation
Serial console enable	Configures ttyS0 for out-of-band access	Management access without GUI/network — emergency recovery	Operational security
Boot verification	Automated boot test after conversion	Catches security misconfigs before production deployment	Change management
UEFI + Secure Boot	Preserves UEFI boot mode, configures OVMF	Secure Boot chain maintained on KVM (when supported)	STIG, FedRAMP
TPM emulation	Configures swtpm for Windows 11 / BitLocker	TPM 2.0 for measured boot and disk encryption	FIPS, BitLocker policy

What Happens Without Security Hardening

Naive Migration (Without hyper2kvm)

- VMware Tools still running — unnecessary services, potential info leak
- SELinux in permissive or disabled (broken contexts)
- Old hypervisor agents phoning home or crashing
- Stale NIC configs with wrong firewall rules
- Cloud agents trying to reach metadata services
- Unnecessary kernel modules loaded
- **Result: Larger attack surface, compliance gaps**

hyper2kvm Migration (Hardened)

- Source hypervisor tools removed completely
- SELinux enforcing with correct file contexts
- Only VirtIO drivers loaded — minimal kernel surface
- Clean network configuration — no stale rules
- Cloud agents disabled or removed
- UEFI/Secure Boot preserved
- **Result: Smaller attack surface, compliance-ready**

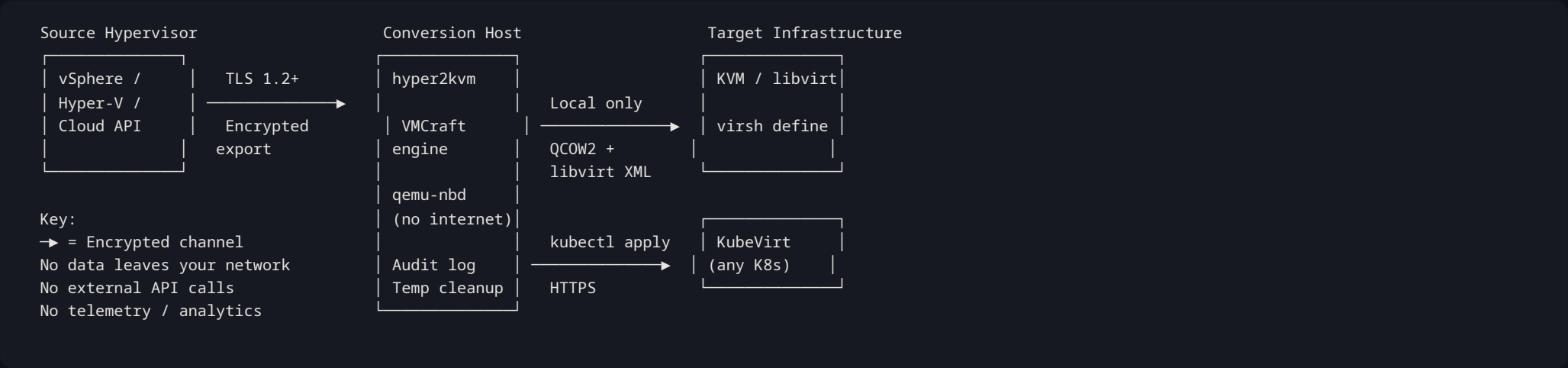
Credential Management & Data Flow

How sensitive data is handled at every stage of the migration pipeline.

Credential Flow — No Plaintext Storage

Credential	Source	Storage Method	Protection
vCenter password	GOVC_PASSWORD env var	Environment variable only — never in config files	Process-level isolation, not written to disk, Redacted() in logs
AWS access keys	AWS_ACCESS_KEY_ID / SECRET	Environment or SecretManager (vault)	Vault encryption, automatic rotation, never in YAML
Azure service principal	AZURE_CLIENT_SECRET	Environment or SecretManager	Short-lived tokens, MSI preferred over keys
SSH private keys	File path reference	Key file on disk with 0600 permissions	Never copied, used in-place, passphrase-protected
API keys (hypersdk)	Generated on creation	Hashed in SQLite store	bcrypt hashed, original shown once at creation
JWT tokens	Generated on login	Memory only — not persisted	Short-lived (configurable expiry), signed with HMAC-SHA256
K8s credentials	kubeconfig file	Reference to kubeconfig path	Standard K8s auth — tokens, certs, or OIDC

Data Flow During Migration — Security Boundaries



YAML Config — Credential-Safe Example

```
# migration.yaml – NO credentials in this file
cmd: vsphere
# vCenter credentials come from environment variables:
#   GOVC_URL, GOVC_USERNAME, GOVC_PASSWORD, GOVC_DATACENTER
# These are set in the shell or systemd unit, not in YAML
vs_action: export_vm
vs_vm: production-db-01
output_dir: ./converted
out_format: qcow2
regen_initramfs: true
emit_domain_xml: true
boot_test: true
# This file is safe to commit to Git – no secrets
```

Open Source Security Advantage

Why open-source migration tools are inherently more secure than proprietary alternatives.

Full Code Audit

- Every line of hyper2kvm + hypersdk is on GitHub
- Your security team can audit the entire codebase
- No hidden backdoors, no obfuscated code
- Static analysis tools (gosec, bandit) can scan freely
- Dependency tree fully visible in go.mod + pyproject.toml
- **Proprietary tools:** "Trust us" — no code access

Patch Immediately

- Found a vulnerability? Fix it yourself, deploy immediately
- No waiting for vendor security patches
- No support ticket escalation process
- No "vulnerability acknowledged, fix in next quarter"
- Fork, patch, deploy in hours — not months
- **Proprietary tools:** Wait for vendor patch cycle

SBOM Ready

- Full Software Bill of Materials from source
- Go: `go mod graph` for complete dependency tree
- Python: `pip freeze` for all packages
- No hidden third-party components
- Meets Executive Order 14028 (US) SBOM requirements
- **Generate SBOM:** `syft` or `cyclonedx-gomod`

No Vendor Risk

- Apache 2.0 — no vendor can revoke your license
- No forced upgrades or subscription renewals
- No "we're changing the license" (like VMware did)
- No "we're discontinuing this product"
- Fork freedom: your copy works forever
- **Lesson from VMware:** Don't trust proprietary vendors

Security Comparison: Open Source vs Proprietary Migration Tools

Security Aspect	hyper2kvm (Open Source)	Proprietary Tools	Why It Matters
Code audit	Full source available	Binary-only, no audit	Can't verify what proprietary tools do with your data
Telemetry	Zero — verifiable in source	Often enabled by default	VM metadata, disk sizes, IP addresses may be collected
Patch speed	Hours (fix yourself)	Weeks-months (vendor cycle)	Zero-day exposure window is critical

SBOM	Generated from source	Vendor-provided (if any)	EO 14028 requires SBOM for government use
Backdoor risk	Auditable — none found	Cannot verify	Trust but verify — can't verify closed-source
License revocation	Impossible (Apache 2.0)	At vendor's discretion	VMware/Broadcom proved this risk is real
Air-gap deployment	Trivial — single binary	Often needs activation/license server	Classified environments can't phone home
Dependency transparency	go.mod + pyproject.toml	Unknown bundled libraries	Supply chain attacks target hidden dependencies

Compliance Scenarios

How organizations use hyper2kvm in regulated environments.

Healthcare (HIPAA)

- **Challenge:** Migrate EMR VMs from VMware — PHI must stay on-premises
- **Solution:** hyper2kvm runs locally, zero cloud upload, audit trail for BAA
- **Controls:** LUKS encryption on QCOW2, RBAC access, JSON audit log
- **Evidence:** Network capture proves zero outbound connections during migration
- **Auditor happy:** YAML config + audit log proves exactly what was done

Financial Services (SOC 2 / PCI DSS)

- **Challenge:** Migrate trading platform — change management, access control
- **Solution:** YAML configs in Git (change history), RBAC in hypersdk
- **Controls:** JWT auth, per-user audit trail, Prometheus monitoring
- **Evidence:** Git history shows who approved each migration config
- **Auditor happy:** Reproducible — same YAML = same result, always

Government / Defense (FedRAMP / STIG)

- **Challenge:** Migrate classified VMs from Hyper-V — fully air-gapped
- **Solution:** Install via USB, convert on isolated network, zero internet
- **Controls:** FIPS mode, STIG-hardened hosts, SELinux enforcing
- **Evidence:** SHA256 checksums on all binaries, SBOM for all dependencies
- **Auditor happy:** No network calls provable, code fully auditable

EU / International (GDPR)

- **Challenge:** Migrate VMs with EU citizen data — data residency required
- **Solution:** On-prem processing, data never leaves jurisdiction
- **Controls:** No cross-border transfer, no third-party data processors
- **Evidence:** Processing records in audit log (Article 30 compliance)
- **DPO happy:** No sub-processors, no data transfer agreements needed

Compliance Checklist for Auditors

#	Control	hyper2kvm Evidence	How to Verify
1	No data exfiltration	Zero outbound network connections	tcpdump during migration — no external traffic
2	Access control	sudo + RBAC (admin/operator/viewer)	Review /etc/sudoers + hypersdk user config
3	Audit trail	JSON audit log with user, action, timestamp	Review audit log file, ship to SIEM
4	Encryption at rest	LUKS-encrypted QCOW2 output	cryptsetup luksDump on output image
5	Encryption in transit	TLS 1.2+ for all exports	Wireshark capture of export traffic
6	Change management	YAML config in Git with commit history	git log shows who, when, what for each migration

7	Credential protection	Env vars / vault — never in config files	grep YAML configs — no passwords or keys present
8	Secure cleanup	Temp files auto-deleted after conversion	ls /tmp after migration — no residual data
9	SBOM	go.mod + pyproject.toml + generated SBOM	syft scan of binary — all dependencies enumerated
10	Reproducibility	Same YAML config = identical migration result	Run same config twice — verify identical output

Security Summary

Every security control at a glance.

Data Protection

- Zero telemetry
- No cloud upload
- LUKS encryption
- TLS in transit
- Secure cleanup
- Air-gap ready

Access Control

- RBAC (3 roles)
- JWT + API keys
- sudo required
- Session management
- Denied access logged
- Multi-tenant support

Audit & Compliance

- 16+ audit event types
- JSON structured logging
- SIEM integration
- Reproducible configs
- SBOM generation
- Git-tracked changes

Guest Hardening

- SELinux relabel
- Hypervisor tools removed
- Cloud agents removed
- Minimal VirtIO drivers
- UEFI / Secure Boot
- TPM emulation

Compliance Frameworks Supported

HIPAA SOC 2 GDPR FedRAMP PCI DSS STIG ISO 27001 SOX
NIST 800-53 CIS Benchmarks EO 14028

Credential Sources

Environment variables, HashiCorp Vault, encrypted file store, Kubernetes secrets, SSH key files. **Never** in YAML configs, command-line arguments, or log output. Passwords redacted in all structured logging.

The Most Secure VM Migration Platform

Zero telemetry. Full air-gap support. Open-source code audit. Enterprise RBAC and audit trail.

HIPAA, SOC 2, GDPR, FedRAMP, PCI DSS, STIG — all aligned.

Your data never leaves your control. Your security team can verify every line of code.